the AS will require the client's redirect URI to be pre-registered to prevent open redirect attacks.

> **DEFINITION** An ***open redirect*** vulnerability is when a server can be tricked into redirecting a web browser to a URI under the attacker's control. This can be used for phishing because it initially looks like the user is going to a trusted site, only to be redirected to the attacker. You should require all redirect URIs to be pre-registered by trusted clients rather than redirecting to any URI provided in a request.

For a web application, this is simply a case of returning an HTTP redirect status code such as 303 See Other,[6] with the URI for the authorization endpoint in the Location header, as in the following example:

```
HTTP/1.1 303 See Other
Location: https://as.example.com/authorize?client_id=test
#A
[CA]&scope=read_messages+post_message    #B
[CA]&state=t9kWoBWsYjbsNwY0ACJj0A    #C
[CA]&response_type=code    #D
[CA]&redirect_uri=https://client.example.net/callback    #E
```

#A The client_id parameter indicates the client.
#B The scope parameter indicates the requested scope.
#C Include a random state parameter to prevent code substitution attacks.
#D Use the response_type parameter to obtain an authorization code.
#E The client's redirection endpoint.